Threat evolution in Q1 2018

GROUP-IB
GLOBAL CYBER SECURITY COMPANY

Table of contents

Introduction 3
Executive summary 4
Forecasts for Q1 2018 8
APT in the Financial Sector 9
Financial threats 13
- Malware for Android 14
- Malware for PC 16
- Attacks on ATM and POS terminals 21
- Sales of access to corporate resources 21
- Phishing attacks 22

State-sponsored APT groups 23
Threats to blockchain projects and cryptocurrencies 34
Data leakage 37

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the USA, Canada and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by government and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums and accumulating information on new trends, threats and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on to the Financial Sector

- The Cobalt hacker group continued its attacks on financial institutions, disguising phishing emails as those from Banco Santander, Western Union, BPC Banking Technologies, Oracle, SWIFT, etc. We note that the attackers started using a new unique malicious software (CobInt).
- The Silence Group is conducting targeted attacks on banks. Their target is most likely card processing.
- Researchers detected a group of SMiShers attacking banks worldwide; the attackers were particularly active in Australia.
- In Q1, the Lazarus group again was involved in theft of crypto currency, and also attacked defense contractors and financial institutions.
- The BlackEnergy group was spotted using a new version of the KillDisk tool in attacks on financial institutions in Latin America.
- On March 27, Malaysia's central bank Negara said it was the victim of a cyber-attack in which hackers sought to steal money through SWIFT. Unauthorized transactions were stopped through prompt actions of the bank's employees. Earlier, in February, India's City Union Bank confirmed that criminals gained access to its systems and made transfers totaling US$1.8 million.
- Cybercriminals attacked Metrolinx, an Ontario-based transit agency.

Financial Threats

- The Gozi banking Trojan is attacking banks in Japan, USA and Canada, Australia, and Italy;
- TinyNuke continued attacking French banks;
- Qbot was detected to attack banks in the US, Canada, Spain; the IcedID banking Trojan is targeting the US, Canada, and the UK;
- The Threadkit exploit kit is actively used to spread such malicious programs as Trickbot, Loki bot, Formbook Formgrabber;
- Trickbot is attacking financial institutions in the US, Canada, Spain, Belgium, Germany, Norway, Argentina, and Peru;
- Hackers started to distribute the Dridex banking Trojan via compromised FTP servers instead of usual HTTP links. Attackers target banks in the US, Australia, Britain, and France.
- In late January 2018, the US first observed jackpotting attacks on ATMs. Purportedly, hackers used the "Ploutus-D" malicious software. Similar attacks were previously tracked in Mexico and Europe;
- In Europe, the Cutlet malware continued to attack ATMs;
- A new POS Trojan PinkKite appeared;
- High activity in the Emotet Trojan was detected. This banking Trojan is also used to deliver additional Trojans to the victim's machine;
- Activity of Tinba, Atmos, ZeusVM decreased;
- The Ramnit Trojan is attacking not only banks but also retailers; it also began to attack banks in Belgium;
- Group-IB experts discovered and investigated a criminal group from Nigeria. The group started its activity in 2012 and is still active. They have created more than 400 phishing web pages which primarily imitate pages of banks and financial institutions worldwide;
- In January, the "Mephistophilus" system designed to conduct targeted phishing attacks was updated;
- Researchers identified the identity of a member of the "Fxmsp" criminal group, which sells access to more than 50 corporate networks belonging to banks, government institutions and hotels;
- We continued to identify RTM attacks on Russian banks and financial companies;

- The Toplel criminal group continued to attack clients of Russian banks;
- The most popular Android banking Trojan on underground forums is Red Alert. Also, a more expensive and high-quality malware "AndyBot" is available;
- Clients of Russian banks were attacked by the following Android Trojans: FlexNet, Agent.sx, Limebot;
- The Asacub Android banking Trojan was active in January, but then this group started using a new Trojan (tracked by Group-IB as Asacub 2);
- In February, the update of the Smoke Bot malware, which originally appeared in 2011, was released. This modular Trojan is primarily used as a loader;
- We continued to track targeted attacks on financial institutions using the Adwind RAT.

Threats to blockchain projects and cryptocurrencies

- In late February, the North Korean Lazarus group attacked clients of the cryptocurrency exchange Falcon Coin.
- A record amount of USD 533 million (in NEM digital currency) was stolen in an attack on a Japanese crypto currency exchange Coincheck. Over 260,000 users were affected. The National Intelligence Service of South Korea says that the attack was most likely organized by North Korean hackers.
- The BlackWallet service, a cryptocurrency wallet provider, fell victim to a cyber-attack, which resulted in the theft of $400,000 in Lumens.
- The RubyMiner crypto currency miner was used to launch massive attacks on web servers in the United States, Germany, United Kingdom, Norway, and Sweden. Despite the large number of compromise attempts observed, only 700 servers worldwide have been successfully enslaved within the first 24 hours of attacks.
- Unidentified hackers stole a crypto currency worth 570 million won ($470,588) from a user in South Korea.
- Criminals started to install the well-known Gozi/Ursnif/ISFB banking Trojan together with the cryptocurrency miner Coinminer, even more enriching its functionality.

Data leakage

- Travel website Orbitz disclosed that 880,000 payment cards may have been exposed in a data breach. Customers' personal information, including full names, payment card information, birth dates, phone numbers, email addresses, physical addresses, billing addresses and genders, may have been exposed in the breach.
- The Equifax international credit agency has admitted that the hack on its systems in late 2017 was far worse than previously thought and that criminals were able to steal sensitive personal information on 145 million customers in the US, UK and Canada. It is now emerged that hackers were also able to access US taxpayer ID numbers and their associated email addresses and phone numbers as well as bank card details.
- A critical vulnerability discovered in the Chrome browser extension of the grammar-checking software Grammarly inadvertently left all 22 million users' accounts, including their personal documents and records, vulnerable to remote hackers.
- In late March, US Sports apparel manufacturer Under Armour disclosed that data associated with 150 million users of the company's fitness app MyFitnessPal were compromised in one of the biggest hacks in history in February 2018.

Threats to the Government sector

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. In Q1 2018, we identified an increased activity of state-sponsored hackers related to the 2018 Winter Olympic Games in Pyeongchang, South Korea.

In Q1 2018 the following active APT campaigns against state institutions were detected:

- A new massive cyberespionage campaign, believed to be the work of the Dark Caracal hacker group linked to Lebanese General Security Directorate (GDGS) in Beirut, has been uncovered. The group has been active since at least January 2012. Dark Caracal has conducted numerous attacks against journalists, military institutions and private companies stealing massive trove of information in 21 countries.
- Cybercriminals continue to attack medical centers and government organizations using Samsam ransomware.
- Unknown hackers are attacking Android users in India using the PoriewSpy malware to collect confidential information.
- In Q1 2018, the APT28 group attacked European government agencies involving updated variants of DealersChoice and SofacyCarberp.
- The Iran-linked OilRig APT group sent spear-phishing emails to companies in the Middle East. Hackers employed a new Trojan called OopsIE.
- The APT15 hacking group is back again, this time stealing sensitive data from governmental departments of the UK.
- The Dragonfly hackers compromised a Cisco router and abused it to harvest credentials later used to hack energy companies in the UK.
- The state-sponsored group PlugX continued its activities against military-industrial complexes in the CIS countries, Japan and the US using the Lurid and Gh0st RAT Trojans.
- After a long break, the Kimsuky hacker group renewed its espionage campaigns against South Korea. Hackers again used spear phishing emails with a malicious attachment leveraging the Hangul Word Processor (HWP) word processing application to target users.
- In February 2018 Chinese hackers began escalating a wave of attacks on U.S. engineering, defense and shipping companies linked to the disputed South China Sea. The suspected Chinese cyber-espionage group dubbed TEMP.Periscope appeared to be seeking information that would benefit the Chinese government.
- The APT37 hacker group has expanded its geographical reach to include targets in Japan, Vietnam and the Middle East. The group appears to be targeting a wider range of industries, including chemicals, manufacturing, aerospace, automotive and healthcare entities.
- The Iran-linked group APT group MuddyWater committed attacks on individuals working for government organizations and telecommunication companies in Asia and the Middle East.
- Researchers detected a new cyber espionage campaign conducted by the Iron Tiger APT group. The new campaign, dubbed by Operation PZChao, is targeting government, technology, education, and telecommunications organizations in Asia and the US.
- Security specialists uncovered a sophisticated threat — dubbed Slingshot— that was used to infect hundreds of thousands of victims in the Middle East and Africa by hacking into their routers. Slingshot is believed to be an operation of the U.S. military's Joint Special Operations Command (JSOC).
- In February 2018, the Chafer group began to use new tools, including the EternalBlue exploit, to attack targets in the Middle East.

- The Sanny APT group conducted a spear-phishing campaign targeting government institutions.
- Unknown hackers targeted the opening ceremony of the 2018 Winter Olympics in Pyeongchang, South Korea, using a unique malware named the 'Olympic Destroyer'.
- A spokesman for the Germany's government confirmed that the government agencies were attacked by hackers about a year ago. Hackers reportedly gained access to a German government network by burying hidden coded instructions into emails which they sent to officials' Microsoft Outlook inboxes.
- The UK Anti-Doping Agency confirmed it had foiled an attack by unknown hackers.
- Unknown hackers compromised the website of a leading Hong Kong Telecommunications company through a watering hole attack.

Forecasts for Q1 2018

- After the arrest of the Cobalt group members, their campaigns will soon subside.
- In Russia, clients of banks will be attacked by the Toplel group, in other regions – by Gozi, Trickbot, Dridex, Qbot, ICEDID.
- At the end of 2017, Silence launched targeted attacks on banks to gain access to ATMs. We believe that they can start using more effective ways to withdraw money from the bank. Primarily, we expect attacks from this group on card processing. The main target of the attackers will be banks in the CIS countries.
- The North Korean group Lazarus will also continue to pose a threat. New attacks are likely to affect SWIFT. We expect that Lazarus will focus on banks in Africa.
- The geography of SMiShing attacks will expand, and the number of attacks on financial organizations in Australia will increase.
- We will continue to observe the growth of threats for the cryptocurrency industry. Primarily, we expect attacks on miners and crypto exchanges. Such attacks will involve more and more state-sponsored hacker groups.
- After the authors of Andromeda Trojan were arrested, an updated version of its main competitor, the Smoke Bot Trojan, appeared. We expect that the Smoke Bot Trojan will be primarily used as a Trojan loader and password stealer.
- The most popular Android Trojan will be Red Alert which is 'marketed' as a low-cost tool on underground platforms. Hackers will also actively employ the Andybot malware, which appeared in late 2017 and is now actively sold on Darknet marketplaces.

APT in the Financial Sector

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks on banks from the Cobalt hacker group	Russia, Kazakhstan, Global	CP-1438-38 - CP-1438-43	2016

In early 2018, the Cobalt group continued active attacks:

- On January 26, phishing emails were sent to Russian banks acting as the BPC Banking Technologies company. After finding the server from which the emails were sent, Group-IB specialists detected two more domains. One of them had already been used by the Cobalt group in September 2017 to send emails. The second domain was also used by Cobalt as a C&C server during the attack on Russian banks in December 2017.
- In January, Cobalt performed another phishing attack on Russian financial institutions acting as Oracle, National Card Payment System, Santander Bank and Western Union.
- In February 2018, cybercriminals sent phishing emails to Russian financial institutions acting as Western Union and Akamai Technologies.
- In late February, another massive attack was conducted. Cybercriminals used domains similar to well-known companies and services - SWIFT, Apple Pay and Google API.
- In March, cybercriminals sent phishing emails purporting to be from IBM and Spamhaus.
- On March 26, 2018, Europol reported of the Cobalt leader was arrested in Spain. The author of Cobalt malware was also arrested, according to reports. However, despite the arrests, the criminals continued to attack banks in Russia and Europe. Even on the date of the official announcement, we identified spear phishing emails which were sent by Cobalt acting. We believe that the activity of the group will decrease, but won't not stop.

Criminal group	Regions attacked	Detection
Toplel	Russia	2015

A criminal group called Toplel, which was actively attacking customers of Russian banks in 2014-2015, returned to the spotlight and renewed its attacks on Russian companies and banks in late October 2017. In order to collect the authentication data (logins, passwords) from various systems, the hackers are still using Pony malware.

We believe that this may lead to a rise in the number of thefts from legal entities via online banking systems; targeted attacks on banks are also possible.

Criminal group	Regions attacked	Related notifications	Detection
DarkCGI	Australia, Great Britain, Canada, China, Sweden, Ireland, the USA	CP-1674	December 2016

Group-IB analysts tracked activity of a criminal group dubbed DarkCGI. The group began operations in December 2016. The hackers send spam containing links to phishing pages, using SMS messages (so-called "smishing") acting as legitimate banks in order to obtain the victim's credentials. The group's targets were clients of 17 different organizations in the UK, Canada, China, Sweden, Ireland, and the USA. However, the key targets of the group are located in Australia.

In addition to financial institutions, hackers attacked an Australian government website, as well as an organization that offers microloans to Australian citizens. Purportedly, attackers retrieved personal data and passport details from the hacked resources to register bank accounts for withdrawing funds from hacked accounts. Hackers sent emails with phishing links to receive credentials of the victim's bank accounts. To control

the entire infrastructure of phishing pages, the group uses the U-Admin software, which is sold on underground forums. This software is a universal administrative panel, which can be used for various purposes.

APT name	Regions attacked	Related notifications	Operation start
Lazarus	Global	CP-1666	2017

Since 2017, the Lazarus hacking group has been conducting an aggressive Bitcoin-stealing campaign. This new campaign, dubbed HaoBao, uses spear phishing emails with malicious emails, posed as employee recruitment.

The campaign lasted from April to October 2017 and used job descriptions relevant to target organizations, in both English and Korean. The 2017 campaign targets ranged from defense contractors to financial institutions, including crypto currency exchanges. The objective was to gain access to the target's environment and obtain key military program insight or steal money.

On January 15, 2018, researchers discovered a malicious document masquerading as a job recruitment for a Business Development Executive located in Hong Kong for a large multi-national bank. The document was distributed via a Dropbox account.

On March 1, 2018, Group-IB notified the customers that, since late February 2018, the Lazarus cybercrime group had been attacking clients of the Falcon Coin cryptocurrency-lending platform. The spear phishing email contained a malicious file named "AGREEMENT.docx". The document appears to be an agreement template for Bitcoin distribution between a customer and a cryptocurrency exchange. The Bankshot Trojan implant was attached to the document. Bankshot serves as a backdoor: it performs control server communications, handles commands issued by the control server, and uninstalls self from the system.

Hackers exploit a critical vulnerability (CVE-2018-4878), which exists in Adobe Flash Player 28.0.0.137 and earlier versions. This vulnerability occurs due to a dangling pointer in the Primetime SDK. Successful exploitation allows an attacker to take control of the affected system.

Later, experts observed the Lazarus Group using the Bankshot implant in targeted attacks against the financial organizations in Turkey.

Simultaneously, Lazarus began spreading malicious documents with a new RAT, attempting to impersonate an employee of an Australia based law firm for commercial and financial services named Holley Nethercote. The document states that they have evaluated several cryptocurrencies and they have put together an investment proposal aimed at FinTech, financial, and other companies who might be interested in taking an investment.

The Lazarus group, also known as Dark Seoul Gang/HIDDEN COBRA/Guardians of Peace started its operations back in 2007. Members of this group are believed to originate from North Korea.

APT name	Regions attacked	Operation start
BlackEnergy	Latin America	March 2017

Researchers at Trend Micro discovered a new version of the KillDisk utility designed for a complete and irreversible data removal. The tools was used in attacks against financial institutions in Latin America.

The BlackEnergy hacking group used KillDisk and ICS-SCADA malware in the attacks that led to power outages in Ukraine back in December 2015. It was also used against mining and railway companies and banks in Ukraine. Later, this malware program was added to other malicious codes, including Petya ransomware. In December 2016, researchers at CyberX discovered a sample of KillDisk malware where crypto ransomware functions were implemented. This option was intended for Windows computers deleting any file stored on disks, except system files and folders.

The BlackEnergy group aka SandWorm, Quedagh has been active since at least 2010. The group is known for their attacks using the BlackEnergy Trojan which was created by a hacker nicknamed as Cr4sh in 2007.

APT name	Regions attacked	Operation start
Targeted attack on the Metrolinx transit agency	Canada	January 2018

In early January 2018, the Canadian transit agency Metrolinx suffered a hacker attack. The attack was a virus, routed through Russia that infected computers at Metrolinx, according to CBC Toronto.

A Crown agency responsible for transit throughout the Toronto and Hamilton areas, Metrolinx also manages the Presto card electronic fare system.

Spokesperson Anne Marie Aikins confirmed to CBC Toronto that the attack took place, but said it did not result in any breach in privacy and did not compromise any safety systems. Aikins could not provide further details about the attack, citing "security reasons."

APT name	Regions attacked	Operation start
Targeted attack on City Union Bank	India	February 2018

In February 2018 India's City Union Bank said that cybercriminals had hacked its systems and transferred nearly over $1.8 million through three unauthorized remittances to lenders overseas via SWIFT.

According to the bank's statement, fraudulent remittances were detected during their reconciliation process on February 7, 2018. City Union said it had been able to block one of the remittances, totaling $500,000, which was being sent through a Standard Chartered Bank (STAN.L) account in New York to a Dubai-based lender.

The second transfer of 300,000 euros ($372,150) was routed through a Standard Chartered Bank account in Frankfurt to a Turkish account. The bank said it was working with the Ministry of External Affairs and officials in Turkey to repatriate the funds.

The third transaction of $1 million was made through Bank of America, New York to a China-based bank. According to the bank's official press release, the beneficiary had claimed the funds by submitting forged documentary evidences.

Financial threats

GROUP IB

GLOBAL CYBER SECURITY COMPANY

Malware for Android

Malware name	Regions attacked	Detection	Notification
Red Alert	Global	May 2017	CP-1575

Currently, the Red Alert Android banking Trojan is quite popular and often purchased on underground resources. At a relatively low price, the client gets an effective malware with a large set of fake pages for attacks on banks worldwide, as well as for cryptocurrency wallets. The author nicknamed Sochi is constantly updating the malware - in March 2018 Red Alert v2 was released. The list of attacked banks is expanding as well.

Malware name	Regions attacked	Detection
AndyBot (Gustuff Bot)	Global (except the CIS countries)	2017

AndyBot has standard functionality of an Android Trojan: manipulates SMS messages, performs calls and USSD requests, displays fake pages, locks the device and uploads photos from infected devices. The Trojan includes injects designed for banks in the US and Australia. . The monthly rental price is $1,000. The seller is a user with the nickname bestoffer.

Malware name	Regions attacked	Detection
FlexNet	Russia	2014

The Trojan requests device administrator privileges. The text of the request is masqueraded as the Google Play Agreement, which distracts the user and leads to the confirmation of rights.

On command from the C&C server the application can:

- change the address of the C&C server
- send an SMS message to the specified number
- send spam messages with the specified text
- forward text messages to the C&C server
- reply to SMS messages and delete them to hide from the user
- run USSD requests
- create a scheduled task - setting up a command template for new bots, taking into account the operator and the country.

Also, Group-IB specialists determined that the authors added phishing dialogs disguised as Google Play and the Uber application to the recent version of FlexNet. The pushing windows are designed to receive victim's bank card data.

Threat name	Detection	Regions attacked
Agent.sx	2015	Russia

Criminals use this banking bot, which has capabilities to send and intercept SMS messages in order to perform unauthorized money transfers through SMS banking. Developers have added an auto-reply function to the malware control panel, which enables attackers to send messages with transfer confirmation automatically. The program also has the functionality to parse SMS messages in order to obtain victim’s card balance. This parser can be customized for any bank. The Trojan also has capabilities to collect bank card data using a Google Play phishing dialog.

Threat name	Detection	Regions attacked
Gugi/Limebot/Lipton	August 2016	Russia

The Trojan displays a phishing dialog box on the top of official applications in order to steal online banking credentials and credit card data. In addition to that, the malware is able to capture SMS messages and contact lists, run USSD requests and send SMS on command from the C&C server. The Trojan spreads via SMS spamming and uses fake windows to capture data.

Threat name	Detection	Regions attacked
Asacub	2014	Russia

Once the victim's device is infected, the Trojan starts sending messages to the entire contact list, and sends SMS to short number 900 in order to find out the balance of the victim's bank card (in the event the victim is a client of Sberbank).

It also has the following functionality: sends a list of installed applications, the browsing history and contact list to the C&C server, sends SMS messages to the specified number, downloads the history of messages to the C&C server, displays phishing pages over legitimate applications, forwards calls to the specified number, sends USSD requests, downloads files from a specified link and installs them.

Threat name	Detection	Regions attacked
Asacub 2	2018	Russia

The criminal group, which had previously used the Asacub malware, started using a new variant dubbed Asacub 2 in January.

A list of attacked applications:

- ru.sberbankmobile
- ru.vtb24.mobilebanking.android
- ru.letobank.Prometheus

The program was distributed under the following names:

- SMS_S
- SMS_MMS
- MMS message
- Message
- Photo
- SMS – Photo
- SMS message

Malware for PC

Malware name	Regions attacked	Related notifications	Detection
ICEDID	USA, Canada, UK	CP-1648	2017

Security specialists originally discovered this banking Trojan in late 2017. This malicious program may be employed to steal financial information and conduct targeted attacks. Researchers revealed that attackers used another Trojan, Emotet, to spread ICEDID.

ICEDID has a modular structure and incorporates techniques of the infamous Zeus Trojan, including web injection, the ability to embed code into processes, grabbing data. One of its distinctive features is the ability to deploy a proxy server on an infected machine and redirect all Internet traffic using this server.

Identified ICEDID samples are designed to target the following banks in the US, Canada and the UK:

HSBC Bank
Royal Bank of Canada
JPMorgan Chase
Bank of America
Blockchain.info
Citibank
The Synovus Financial Corporation
Toronto-Dominion Bank (TD BANK)
Huntington Bancshares, Inc.
Chase Bank
Charles Schwab Corporation
NETELLER
Canadian Imperial Bank of Commerce (CIBC)
Wells Fargo
Fifth Third Bank (53 bank)
Capital One
KeyBank
Regions Financial Corporation
American Express
Halifax
TSB Bank
E-Trade

Name	Detection	Attacked countries
Emotet	2014	Globaltet

Emotet is a modular banking Trojan that includes the following modules: its own installation module, a banking module, a spam bot module, a module to grab data from MS Outlook and a module for organizing DDoS attacks.

In July 2017, an Emotet sample was identified, which has the ability to self-propagate through the local network, due to the brute-force module, through which it accesses various accounts.

Recently, Emotet has been used as a platform to deliver additional malicious tools, like Qbot and ICEDID.

Name	Detection	Attacked countries
Qbot	2009	USA Canada Spain

Discovered in 2009, the QakBot or Qbot banking Trojan has significantly evolved over time. The malware features a modular design, is multithreaded, and includes components designed to steal keystrokes, online banking credentials, digital certificates, authentication tokens, and cookies, implement a backdoor, and create a SOCKS proxy. It also has the functionality to bypass AV solutions. The program is primarily used to target businesses, stealing money from their bank accounts. QBot is able to spread like a worm by self-replicating through shared drives and removable media.

Group-IB specialists retrieved a configuration file of the last QBot version. According to this file, the malware is designed to attack the following targets:

Citibank
Huntington Bancshares, Inc.
Toronto-Dominion Bank (TD BANK)
Bank of America
First Citizens Bank
Citizens Financial Group
First Tennessee Bank
Banco Bilbao Vizcaya Argentaria (BBVA)
Eastern Bank
Fifth Third Bank (53 bank)
FirstMerit Bank
JPMorgan Chase
KeyBank
Suntrust
Scotiabank
Usbank
Capital One
Frostbank
PNCbank
Mandtbank
Websterbank

Malware name	Regions attacked	Detection
Gozi (ISFB, Ursnif)	Japan, USA, Canada Australia, Italy	2007

In Q1 2018, at least four different campaigns using Gozi were identified. The operations targeted financial institutions in the US and Canada, Italy, Japan and Australia. The attackers began to install Gozi together with the cryptocurrency miner Coinminer, even more enriching its extensive functionality.

Gozi's targets are as follows:

tecmarket.it
cbibanking.it
cim-italia.it
credem.it
bnl.it
businesswaybnl.it
csebo.it
fideuramonline.it
icbpi.it
intesasanpaolo.com
bcp.it
ubibanca.com
mps.it
relaxbanking.it
quercia.com
unicreditcorporate.it
unicredit.it
citibank.citigroup.com
pncbank.com
capitalonebank.com
usbank.com
netteller.com
simmonsbank.com
centurybankonline.com
firstteller.com
wellsfargo.com
paypal.com
bmo.com
cibc.com
desjardins.com
royalbank.com
scotiabank.com
td.com
usaa.com
chase.com
bankofthewest.com
citibank.com
bnymellon.com
iberiabank.com
capitalone360.com
fundsxpress.com
hsbcnet.com
suntrust.com
unionbank.com
rbs.com
navyfederal.org
rbc.com
banquelaurentienne.ca
mb.ca
meridiancu.ca
bnc.ca
coastcapitalsavings.com
conexus.ca
prospera.ca
servus.ca
valleycreditunion.com
vancity.com
tangerine.ca
simplii.com
intesasanpaolo.com
unicredit.it
bancobpmspa.com
mps.it
sella.it
bancobpm.it
tdbank.com
bankofamerica.com
regions.com
frostcashmanager.com

jpmorgan.com
juroku.co.jp
chugin.co.jp
ryugin.co.jp
daishi-bank.co.jp
hokkokubank.co.jp
tsukubabank.co.jp
awabank.co.jp
miyagin.co.jp
hirogin.co.jp
rakuten-bank.co.jp
saisoncard.co.jp
idemitsucard.com
mufg.jp
aeon.co.jp
pocketcard.co.jp
cedyna.co.jp
orico.co.jp
resonabank.co.jp
shinkin-ib.jp
japannetbank.co.jp
coincheck.com
coin.z.com
bitflyer.jp
blockchain.info
japanpost.jp
Bankofmelbourne
BankSA
StGeorge
Westpac

Malware name	Regions attacked	Detection
Trickbot	The USA, Canada, Spain, Belgium, Germany, Norway, Argentina, Peru	Fall 2016

Trickbot is a banking Trojan hat has a similar functionality to the Dyre (Dyreza) malware.

The samples detected in Q1 2018 are targeting the following banks:

Fifth Third Bank (53 bank)
Caisses Desjardins
Citibank
Bank of America
American Express
Australia and New Zealand Banking Group
BB&T Bank
Sparda-Bank
Capital One
Banco Bilbao Vizcaya Argentaria (BBVA)
Banco Mare Nostrum, S.A.
Bank of Montreal
Caixa
Canadian Imperial Bank of Commerce (CIBC)
Commerzbank
Wells Fargo
Toronto-Dominion Bank (TD BANK)
Frostbank
Commonwealth Bank of Australia
NETELLER
Suntrust
Usbank
Scotiabank
Fifth Third Bank (53 bank)
Lloyds Bank
triodos.be
belfius.be
cbc.be
degroof.be
keytradebank.be
montepaschi.be
vanlanschot.be
nagelmackers.be
dnb.no
portalbank.no
sparebank1.no
storebrand.no
bancofar.es
bancopopular.es
bancsabadell.com
sparda.de
bw-bank.de
consorsbank.de
mbs.de
nispa.de
sparkasse.de
volkswagenbank.de
bfsonline.es
cetelem.es
intesasanpaolo
kutxabank.es

Name	Detection	Attacked countries
TinyNuke	2017	Франция

Examples of attacked banks are presented below:
Cic
Credit Agricole
Creditmutuel
Bnpparibas
Lcl
Banquepopulaire

Name	Detection	Attacked countries
Dridex	2014	USA, UK, France, Australia

This banking Trojan has actively evolved since 2014. The tool is designed to steal banking and personal information by injecting itself into web browsers.

In January 2018, researchers tracked a new phishing campaign distributing Dridex. Malicious emails were sent from compromised accounts to top-level domains (primarily .COM), targeting users in France, the United Kingdom and Australia. The emails again originated from the Necurs botnet, which has long been one of the main distribution channels for Dridex. The campaign used two types of documents including a DOC that abuses DDE to execute shell commands to download malware and a XLS file with a Macro that downloads Dridex. A non-typical feature of this campaign is that the malware uses compromised FTP sites instead of the usual HTTP link as download locations for malicious documents.

According to the configuration file, the malware was targeting the following banks in Q1 2018:

1st&t
Wellsfargo
Raiffeisen_ch
Cooperativebank
Ulsterbank
Rbs
Lloyds
Hsbc
Barclays
Tsb
Metrobank
Nationwide
Santander
Labanquepostale
Societegenerale
Credit-agricole
Caisse-epargne
Humebank
Jpmorgan
Boa
Pnc
53
Bbt
Bnycash
Bremer
Fidelity
Usbank
Tdbank
Scotiabank
Bmo
Huntington
Chase
Amex
Usaa
Wellsfargopers
Schwab
Tesco
Citi
ING
Bankofscotland

Malware name	Regions attacked	Detection
Ramnit	Global	2010

The Ramnit banking Trojan was first discovered in 2010. The Ramnit botnet was disrupted in a joint operation of Europol and security firms in 2015. However, in early 2017, hackers again started using the Trojan to compromise credentials of a Dutch online banking system, as well as bank cards of banks in Canada, Germany, the United States, France and the United Kingdom.

Analysis of the recent Ramnit samples shows that this Trojan is now targeting not only banks, including Bank of America, CitiBank, PNC, Chase, TD Bank, US Bank, but also retail eCommerce sites, including Amazon.com, Best Buy, Forever 21, GAP, Zara, Carter's, OshKosh B'gosh, Macy's, Victoria's Secret, H&M, Overstock.com and many others. Ramnit can inject an external script with an additional request and ask the user for whatever it wants. In this case, the script asked for bank card number, expiration date, CVV code, cardholder's name, owner's address, phone number, date of birth, social security number. This means that web injects used for retail purchases in some cases allow attackers to steal even more data than through injections for banks (where they usually compromise only data related to bank cards).

In addition, researchers detected a Ramnit sample attacking Belgian banks: Argenta, ING, Axabank.

Threat name	Detection	Regions attacked
RTM	2015	Russia

The modular Trojan is written in Delphi. Based on its functionality, the Trojan is designed to attack RBS and payment systems. The last detected sample of the Trojan searched for the following RBS systems on the infected machine: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, VTB24.

The RTM group has the main control panel and a separate Proxy panel for banks with which they use a specific technique – all requests are forwarded to phishing servers, where traffic is proxied.

Threat name	Detection	Related notifications	Regions attacked
Smoke Bot	2011	CP-1661	Global

In February 2018, we discovered a new topic about the sale of an updated version of the "Smoke Bot" malware (aka Sharik, Dofoil), which originally appeared in 2011.

This modular Trojan has the following functionality: a password stealer, form grabber, a module for DDoS attacks, a hidden Team Viewer module, etc. However, the main purpose of this malicious program is the resident loader function, which means that attackers can use Smoke Bot to infect the victim with other malicious programs.

The updated Smoke Bot variant supports 32-bit and 64-bit versions of operating systems, and contains a web injection to bypass HIPS (Host-based Intrusion Prevention System).

Threat name	Detection	Related notifications	Regions attacked
Adwind RAT	2012	CP-1667	Global

AdWind is a cross-platform remote access tool (RAT) which is distributed through a single malware-as-a-service platform. This means that anyone can pay small dollars (from $25 to $300) for the service and use the malicious tool to their advantage. Its distinctive feature is that it is fully implemented in Java. This malware, originally named as Frutas, has been developed for several years, with first samples dating back to 2012.

In early 2018, we detected spear phishing emails containing AdWind, which targeted financial organizations. Attackers used the Qrypter service to bypass AV soultions.

Attacks on ATM and POS terminals

- In late January 2018, ATM jackpotting was detected for the first time in the United States. Similar attacks were previously tracked in Mexico and Europe. The Ploutus-D malware was likely involved in these campaigns. This malicious software is designed to steal money from ATMs. The Trojan was first tracked in 2013 in Mexico. In the United States, one of the involved criminal groups was detained.
- A new family of point-of-sale malware, dubbed PinkKite, has been identified by researchers at Kroll Cyber Security. The PoS malware implements classic memory-scraping feature and procedures for data validation. Where PinkKite differs is its very small size (it is less than 6kb), built-in persistence mechanisms, hard-coded double-XOR encryption (used on credit card numbers) and backend infrastructure that uses a clearinghouse to exfiltrate data to (POS malware typically sends data to the C&C server). In fact, the PinkKite operators used three clearinghouses (or depots) that the malware sent data to in the observed campaign. These were located in South Korea, Canada and the Netherlands.

- The PinkKite executable, the researchers discovered, attempts to pass as a legitimate Windows program and uses names such as Svchost.exe, Ctfmon.exe and AG.exe for that. After scrapping credit card data from the system memory, PinkKite validates card numbers using a Luhn algorithm. To complicate malware detection and analysis, the malware also employs another layer of obfuscation via a double-XOR operation that encodes the 16 digits of the credit card number with a predefined key. Following this, the credit card data is stored in compressed files with names such as .f64, .n9 or .sha64. Each record can contain up to 7,000 credit card numbers, a lot of records are periodically sent manually using a separate Remote Desktop Protocol (RDP) session to one of the three PinkKite clearinghouses.
- Attackers are actively using the Cutlet malware to steal cash from ATMs. Successful thefts were identified in Belgium and Hungary. Attacks were conducted on Wincor Nixdorf ProCash ATMs.

Sales of access to corporate resources

Group-IB specialists identified the identity of an Fxmsp group member, who was selling the access to more than 50 corporate networks, including banks, government networks and hotels on hacker forums.

Through communications with the criminal, Group-IB experts found out that the companies had been hacked by a group of cybercriminals.

The attacker described in detail the scheme of penetration into the network and ensuring malware persistence using a backdoor. Attackers sell access to infected networks for over $100,000 for a large bank and at least $15,000 for retailers.

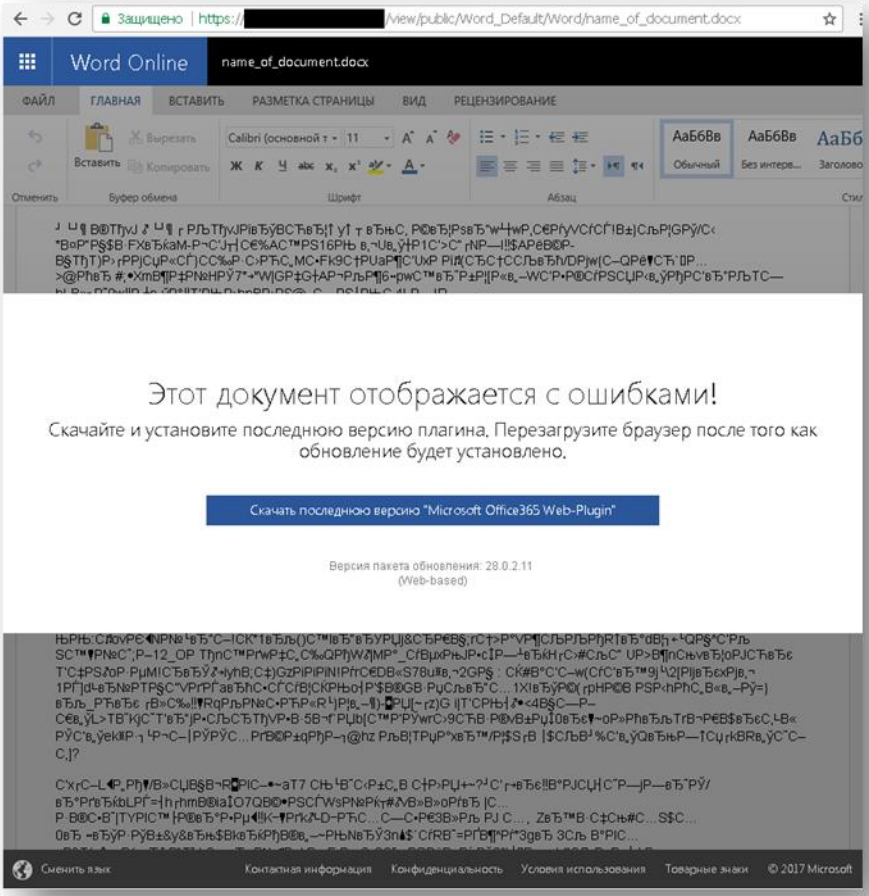
Detailed information on this threat and a list of affected companies are available in Notification CP-1656.

Phishing attacks

Phishing remains one of the most popular hacking techniques across the world without requiring advanced technical skills.

- Group-IB specialists have discovered and deeply analyzed a criminal group originating from Nigeria. The group has been active since 2012. Over time, they have created more than 400 phishing web pages. The majority of phishing pages target banks and financial institutions worldwide. In addition to phishing, the group performed spam email campaigns. These emails redirected victims to the self-developed phishing pages. The victim was informed that he can get a large amount of money (for example, a million dollars) and needs to go to the phishing page and fill in the information about himself (full name, passport details, credit card details). Group-IB specialists also identified the identity of the group leader and several members. Details are provided in Notification CP-1675.
- In January, an updated version of the Mephistophilus system designed to conduct spear phishing attacks appeared on sale on an underground forum.
  This system originally appeared on sale in 2016. This phishing kit uses web fakes offering the victim to download malware masqueraded as "plug-in update" (MS Word, MS Excel or PDF) to view the contents of the document.

  An example of Word fake web page displayed to the victim is presented below:



Once the victim clicks on “Download the latest version of Microsoft Office 365 Web-Plugin”, the malware starts downloading the payload on the machine. Detailed information on this threat is provided in Notification CP-1668.

State-sponsored APT groups

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT name	Regions attacked	Operation start
Dark Caracal	Global	January 2012

In early January 2018, The Electronic Frontier Foundation (EFF) and mobile security company Lookout uncovered a new malware espionage campaign infecting thousands of people in more than 20 countries. The threat actor dubbed Dark Caracal has been operating since at least 2012.

Dark Caracal, a surveillance-toolkit-for-hire that has been used to siphon off amounts of data around the world, appears to be controlled from the Lebanon General Directorate of General Security in Beirut. It shares its backend infrastructure with another state-sponsored surveillance campaign, Operation Manul, which the EFF claims was operated by the Kazakhstan government last year.

Dark Caracal is using the same infrastructure as was previously seen in the Operation Manul campaign, which targeted journalists, lawyers, and dissidents critical of the government of Kazakhstan. The campaigns span across 21+ countries and thousands of victims. Types of data stolen include documents, call records, audio recordings, secure messaging client content, contact information, text messages, photos, and account data, browsing history and location.

The group used basic social engineering via posts on Facebook groups and WhatsApp messages, encouraging users to visit a website controlled by the hackers. Besides its own custom malware Pallas, Dark Caracal also used FinFisher and CrossRAT surveillance tools.

According to the report, the APT group conducted large-scale espionage campaigns targeting governments, military personnel, utilities, financial institutions, manufacturing companies, defence contractors, medical practitioners, education professionals, academics, and civilians from numerous other fields.

APT name	Regions attacked	Operation start
Targeted attacks using Samsam ransomware	Global	December 2017

Since early 2018, cyberattacks employing SamSam ransomware have occurred at Indiana-based Hancock Health Hospital and Adams Memorial Hospital, cloud-based electronic health record (EHR) provider Allscripts, the municipality of Farmington in New Mexico, an undisclosed US industrial control system company.

SamSam is a ransomware family known for targeting the healthcare industry in the past. Unlike traditional ransomware, SamSam does not rely on social engineering techniques like malicious email attachments. This ransomware variant appears to be distributed through unpatched servers and uses them to compromise additional machines that hackers use to identify key data systems to encrypt.

Officials at Hancock Health, a regional hospital in Indiana, explained they paid attackers $55,000 because restoring from backups would have taken days or weeks when they needed systems up sooner. The analysis of Bitcoin address specified in the ransom note shows criminals have made nearly 26 Bitcoin (roughly $300,000) since December 2017.

On March 22, 2018, computer systems in the City of Atlanta were infected by the SamSam ransomware. The cyberattack was confirmed by the City officials. According to the official message on Twitter “the City of Atlanta is currently experiencing outages on various customer facing applications, including some that customers may use to pay bills or access court-related information”.

APT name	Regions attacked	Operation start
Targeted attacks using PoriewSpy Trojan for Android	India	2017

Researchers at Trend Micro discovered attacks on Android users in India performed by using PoriewSpy spyware.

PoriewSpy is able to steal confidential information stored on the victim's devices: SMS messages, call logs, contacts, location and a list of files on the SD card, and it can also record voice calls made by victims. Experts believe that hackers may have links with a suspected cyberespionage group detected in 2016, which could be involved in attacks on government officials.

In addition to PoriewSpy, the group is suspected to use DroidJack or SandroRAT tools. DroidJack is a remote access Trojan (RAT) that allows intruders to take full control of a user's Android device when installed.

APT name	Regions attacked	Operation start
APT28	Europe, North America	February 2017

At the beginning of February 2018, researchers discovered a new attack of the APT28 hacker group targeting two government institutions related to foreign affairs in Europe and North America (one of the attacked organizations is the embassy of Romania in Moscow). The initial attack vector leveraged a phishing email using the subject line of Upcoming Defense events February 2018 with a malicious attachment. A sender address claims to be from <events@ihsmarkit.com>. IHSMarkit is a well-known supplier of information and analysis associated with the defense and government sector.

The attached document presents itself as a standard macro document but has all of its text hidden until the victim enables macros. Notably, all of the content text is accessible to the victim even before macros are enabled. However, a white font color is applied to the text to make it appear that the victim must enable macros to access the content. Simultaneously, the macro gets the contents of certain cells to obtain the base64 encoded payload and writes this data to a specially created file. The macro then decodes the contents of this text file and outputs the decoded content to a file with an .exe extension, which is started after a 2-second delay. The file is a loader that decrypts the payload (a SofacyCarberp variant) and creates a .bat file for its further launch. The payload performs initial reconnaissance by gathering system information and sending it to the C&C server (cdnverify.net) prior to downloading additional tools to the system.

On March 12, 2018, researchers observed the group carrying out a new attack on a European government agency involving an updated variant of the DealersChoice exploit, which allows them to bypass analysis mechanisms. The attack relied on a spear-phishing email with a subject of "Defence & Security 2018 Conference Agenda" that had an attachment with the same filename.

Opening the decoy file does not immediately run malicious code to exploit the system. Instead, the user must scroll to the third page of the document, which will load a Flash object embedded in an image that contains ActionScript that will attempt to exploit the user's system to install a malicious payload. It appears that the actors used ActionScript from an open source video player called "f4player". The developer modified the f4player's ActionScript to include additional code to decrypt an embedded Flash object and an event handler. The event handler calls a function that loads a second Flash object containing an exploit code. The ActionScript then starts by gathering system data and issues an HTTP GET with the system data to the C&C server.

The group APT28 (Fancy Bears, Sofacy, Pawn storm, Sednit and Strontium), first discovered in 2004, has been associated with many attacks against political, information and military targets around the world.

APT name	Regions attacked	Operation start
OilRig	Middle East	January 2018

In January 2018, the OilRig group attacked organizations in the Middle East. The main vector of attacks are spear-phishing emails.

On January 2, CrowdStrike specialists discovered a decoy document with the extension .CHM and the name in Arabic (the translation into English is as follows: "*Minutes of a meeting in the Kingdom of the Bahrain*"). The Compiled HTML Help format (CHM) is widely used to provide context-sensitive help for Windows applications. The malware collects data about the system and ensures its persistence using the "GoogleUpdatesTaskMachineUI" task, which indicates an obvious attempt to deceive the user.

On January 8, 2018, OilRig sent phishing emails with the subject 'Beirut Insurance Seminar Invitation' to an insurance agency in the Middle East. Two delivered letters contained a document named 'Seminar-Invitation.doc', containing the OopsIE payload.

On January 16, 2018, researcher observed an attack on a Middle Eastern financial institution. Instead of using an attached document with malicious macro (which is tracked by Palo Alto Networks as ThreeDollars), this attack involved delivering the OopsIE Trojan directly to the victim, most likely using a link in a spear phishing email.

Palo Alto Networks also identified another sample of ThreeDollars, with the file name *strategy preparation.dot*. The primary difference from their previous tactics was that this sample was encrypted and password protected. Typically, password protected documents is commonly used by adversaries as an evasion tactic to bypass automated analysis mechanisms due to the password requirement for successful execution.

To ensure its persistence in the system, the Trojan creates a scheduled task, which would run it every three minutes. The Trojan uses HTTP to communicate with its C&C server, with all requests looking as if they came from a legitimate browser. The available commands are: Run command; Upload a file; and Download a specified file.

OilRig (APT34) is an Iran-linked APT group operating since late 2015. The group focuses on government and commercial institutions the Middle East, as well as countries of interest to Iran. The group's operations against foreign interests have been mostly espionage campaigns. The threat actors have a wide variety of tools at their disposal. In recent incidents they were detected to employ ALMA Communicator and OopsIE.

APT name	Regions attacked	Operation start
APT15	Great Britain	May 2017

In March 2018, NCC Group specialists reported two previously unknown backdoors, which were used in an attack against a UK government contractor launched by the APT15 China-linked group. These backdoors helped the threat actor collect data related to the UK government's military technology. The networks were compromised from May 2016 until late 2017 and infected over 30 contractor controlled hosts, said the NCC Group.

In its investigation, it found new backdoors that it labelled RoyalCli and RoyalDNS used by the group, in addition to BS2005, a tool that the group has traditionally been linked with. The RoyalCli backdoor appears to be an evolution of BS2005 and uses familiar encryption and encoding routines. RoyalCli and BS2005 both communicate with the attacker's command and control (C2) through Internet Explorer (IE) by using the COM interface IWebBrowser2. Due to the nature of the IE injection technique used by the HTTP-based backdoors, a number of C2 commands were cached to disk.

When NCC Group initially discovered APT15, they ejected the group from the victim's network. However, a few weeks later, APT15 later managed to regain access through the corporate VPN solution using a VPN certificate stolen from a compromised host – and this time, the group was using a newer backdoor – RoyalDNS. The persistence mechanism used by RoyalDNS was achieved through a service called 'Nwsapagent'.

Researchers said additional tools were used by the group including archiving tool WinRAR, a Microsoft SharePoint tool known as "spwebmember", an unidentified network scanning/enumeration tool, and Mimikatz.

APT15, aka Ke3chang, Mirage, Vixen Panda GREF and Playful Dragon, has been tied to espionage campaigns against Indian embassy personnel in 2016, and the attack targeting European diplomats and ministries of foreign affairs discovered in 2013. Attackers are believed to be operating from China.

APT name	Regions attacked	Operation start
Dragonfly	UK, USA	March 2016

Since at least March 2016, Dragonfly cyber actors have been targeting government entities and multiple US critical infrastructure sectors, including the energy, nuclear, commercial facilities, water, aviation, and critical manufacturing sectors.

Hackers attacked peripheral "staging targets" which could be further used as stepping stone into the intended targets and storages for malicious software. Staging targets included third party firms supplying services and support to the main targets but may have less secure networks.

The threat actors in this campaign employed a variety of TTPs, including:

- spear-phishing emails (from compromised legitimate account),
- watering-hole domains,
- credential gathering,
- open-source and network reconnaissance,
- host-based exploitation, and
- targeting industrial control system (ICS) infrastructure.

In addition, Cylance has discovered that a core Cisco was compromised by DragonFly in order to further penetrate the networks of energy companies in the UK.

According to experts, a core Cisco router relied upon by one of Vietnam's largest oil rig manufacturers was compromised in an endeavor to harvest credentials that were later used to attempt to penetrate a handful of energy companies in the UK around March of 2017.

When a malicious document was opened, the victim was connected to a compromised router that automatically authenticated to the malicious SMB server. This technique enabled the router to collect all the credentials entered.

The Dragonfly hacker group (also known as Energetic Bear and Crouching Yeti) has been active since 2010. Experts believe that hackers operate from Russia. A typical feature of this group is the use of public hacking and administrative tools - PowerShell, PsExec, Bitsadmin and others.

APT name	Regions attacked	Operation start
PlugX	Russia, Japan, Mongolia, Belarus, the USA, Tajikistan, Uzbekistan, Kyrgyzstan, Kazakhstan, and Ukraine	April 2017

Since April, 2017, the PlugX has been detected in targeted attacks against military and industrial sectors in the CIS countries, Japan and the United States, with 17 companies affected.

Attackers infected computer networks of defense and industrial enterprises by sending spear-phishing messages with malicious attachments. Malicious emails were sent with such subjects as "compensation to servicemen for renting housing" and "salary increase for servicemen" from the e-mail addresses mo_mil@mail.ru and mo.belo@bk.ru.

Hackers used the following tools: the Lurid malware (known as Enfal), which allows the threat actor to collect information from the infected computer independently, and Gh0st, a RAT-type tool.

Group-IB specialists have long been monitoring the activity of the PlugX group, also known as TA459/Gulpix /Korplug /Kaba, which has been active since 2008. In 2015, we notified Threat Intelligence customers that an official mailbox of a Russian Defense Ministry officer was compromised and used by these attackers to send emails with a malicious attachment.

APT name	Regions attacked	Operation start
Kimsuky	South Korea	January 2018

After a long break, the Kimsuky hacker group renewed its espionage campaigns against South Korea. Hackers again used spear phishing emails with a malicious attachment leveraging the Hangul Word Processor (HWP) word processing application to target users.

In January 2018, attackers sent an attachment with the name "남북 사회 문화 협력 의 비전 비전 과 과 과. Hwp" (translated as North and South social and cultural cooperation: vision and challenges). The file contains a shell code that uses the security vulnerability. The specialists compared the documents sent in this attack and the attacks of November 2016 and December 2017. Analysis of the code 'HwpSummaryInformation' in the delivered documents shows that there are 100% coincidences in all three mailouts.

When the malicious code is executed, it attempts to connect to a specific foreign host server in order to obtain additional commands. The emails purported to be sent from a domain similar to the Daum postal service in South Korea.

APT name	Regions attacked	Operation start
TEMP.Periscope	USA, Europe	February 2018

Since February 2018, researchers have been tracking an ongoing wave of intrusions targeting US engineering and maritime entities, especially those connected to South China Sea issues. The campaign is linked to a group of suspected Chinese cyber espionage actors, dubbed TEMP.Periscope. Identified victims were mostly found in the United States, although organizations in Europe and at least one in Hong Kong have also been affected.

The current wave of identified intrusions likely reflects a concerted effort to target sectors that may yield information that could provide China an economic advantage, research and development data, intellectual property, or an edge in commercial negotiations.

Hackers sent spear-phishing emails with malicious attachments that exploited CVE-2017-11882 vulnerability. In their recent spike in activity, TEMP.Periscope has leveraged a relatively large library of malware. These tools include:

- AIRBREAK: a JavaScript-based backdoor that retrieves commands from hidden strings in compromised webpages and actor controlled profiles on legitimate services.
- BADFLICK: a backdoor that is capable of modifying the file system, generating a reverse shell, and modifying its command and control (C2) configuration.
- PHOTO: a DLL backdoor also reported publicly as “Derusbi”, capable of obtaining directory, file, and drive listing; creating a reverse shell; performing screen captures; recording video and audio; listing, terminating, and creating processes; enumerating, starting, and deleting registry keys and values; logging keystrokes, returning usernames and passwords from protected storage; and renaming, deleting, copying, moving, reading, and writing to files.
- HOMEFRY: a 64-bit Windows password dumper/cracker.
- LUNCHMONEY: an uploader that can exfiltrate files to Dropbox.

- MURKYTOP: a command-line reconnaissance tool.

Active since at least 2013, TEMP.Periscope has primarily focused on attacks against engineering firms, shipping and transportation, manufacturing, defense, government offices, and research universities. However, the group has also targeted professional/consulting services, high-tech industry, healthcare, and media/publishing.

APT name	Regions attacked	Operation start
APT37	Japan, Vietnam and the Middle East.	2017

According to FireEye, the APT37 group expanded its attacks to Japan, Vietnam and even the Middle East last year. The list of targets includes organizations in the chemicals, manufacturing, electronics, aerospace, healthcare, and automotive sectors.

One of the targets in the Middle East was a telecommunications services provider that had entered an agreement with the North Korean government. The deal fell through, which is when APT37 started hacking the Middle Eastern company, likely in an effort to collect information, FireEye said.

This malware has been delivered using social engineering tactics, watering holes, and even torrent sites for wide-scale distribution. The hackers leveraged several vulnerabilities in Flash Player and in the Hangul Word Processor to deliver several types of malware.

The arsenal of the group includes the RUHAPPY wiper, the CORALDECK exfiltration tool, the GELCAPSULE and HAPPYWORK downloaders, the MILKDROP and SLOWDRIFT launchers, the ZUMKONG infostealer, the audio-capturing tool SOUNDWAVE, and backdoors tracked by FireEye as DOGCALL, KARAE, POORAIM, WINERACK and SHUTTERSPEED.

Specialists at East Security Response Center (ESRC) discovered that in March 2018 the group launched a spear-phishing campaign targeting specific Android devices.

According to the report, attackers sent fake emails purporting to be a notification about a threat to personal information security on a popular portal. Emails contained a link to the malicious APK file, which was masqueraded as an application "Naver vaccine app". After installation, a shortcut was displayed with the "Naver Defender" app name.

APT37 (aka Reaper, Red Eyes, Geumseong121, Group123 and ScarCruft) has been active since at least 2012.

APT name	Regions attacked	Operation start
MuddyWater	India, Turkey, Pakistan and Tajikistan	January 2018

From January 2018 to March 2018, FireEye specialists observed the MuddyWater group sending spear phishing emails with malicious macro-based documents to individuals working for government organizations and telecommunication companies in Asia and the Middle East.

Hundreds of hacked websites were used as proxy.

- From January 23 to February 26 they targeted Turkey, Pakistan, and Tajikistan.
- From February 27 to March 5 the group attacked India, Pakistan, and Turkey.

The documents purported to be from the National Assembly of Pakistan, the Turkish Armed Forces, Institute for Development and Research in Banking Technology (established by the Reserve Bank of India), the Ministry of Internal Affairs of the Republic of Tajikistan.

When successfully executed, the malicious documents install a backdoor tracked as POWERSTATS (detected by Trend Micro as TROJ_VALYRIA.PS).

The first part of the campaign (from Jan. 23, 2018, to Feb. 26, 2018) used a macro-based document that dropped a VBS file and an INI file. The INI file contains the PowerShell command, which will be executed by PowerShell using the command line generated by the VBS file (VBS_VALYRIA.DOCT).

The second part of the campaign (from Feb. 27, 2018, to March 5, 2018) used a new variant of the macro that does not use VBS for PowerShell code execution. Instead, it uses one of the recently disclosed code execution techniques leveraging INF and SCT files.

The main function performed by the SCT file is to Base64 decode the contents of WindowsDefender.ini file and execute the decoded PowerShell Script. A specific feature of this script is that it contains a variable which stores a list of proxy URLs. This list will be used to interact with the C&C server.

During analysis, FireEye experts observed a code section with a message written in Chinese. The message is displayed in the case of an error while connecting to the C2 server. Malware writers sometimes like to embed such false flags into their programs to confuse researchers.

MuddyWater (aka TEMP.Zagros) is an Iran-nexus threat actor that has been active since at least February 2017. They are targeting government and defense entities, oil and telecommunications companies.

APT name	Regions attacked	Operation start
Iron Tiger	Asia, North America	July 2017

Malware researchers from Bitdefender have discovered and monitored for several months a new cyber espionage campaign from the Iron Tiger APT group. The campaign, dubbed by Operation PZChao, is targeting government, technology, education, and telecommunications organizations in Asia and the US.

The campaign has been monitored since July 2017 and was dubbed PZChao because of the name of the domain at which its command and control server resides.

PZChao attacks begin with highly targeted spam e-mails containing a malicious VisualBasic Script (VBS) attachment which then downloads further malicious components, including Bitcoin miner, Mimikatz tool and modified Gh0st RAT, which has a wide range of capabilities for cyber espionage. With these tools, attackers took entire control of infected systems and uploaded valuable data to C&C servers.

Active since 2010, Iron Tiger, also known as "Emissary Panda" or "Threat Group-3390," is a Chinese advanced persistent threat (APT) group.

APT name	Regions attacked	Operation start
Slingshot	Kenya, Yemen, Afghanistan, Libya, Mauritius, Congo, Jordan, Turkey, Iraq, Sudan, UAE, Somalia and Tanzania	2012

In March 2018, Kaspersky Lab researchers uncovered a sophisticated threat —dubbed Slingshot— that was used to infect hundreds of thousands of victims in the Middle East and Africa by hacking into their routers.

According to the report, the APT group exploited zero-day vulnerabilities in routers used by the Latvian network hardware provider Mikrotik to drop a spyware into victims' computers.

Although it is unclear how the group managed to compromise the routers at the first place, researchers pointed towards WikiLeaks Vault 7 CIA Leaks, which revealed the ChimayRed exploit, to compromise Mikrotik routers.

After hacking into the router, a malicious library (DDL) is loaded into the victim's computer memory, which eventually connects to the C&C server and downloads the payload of Slingshot program.

Slingshot consists of two modules:

- Cahnadr (another name for NDriver) - has the functions of anti-debugging, rootkit and traffic analysis, installation of other modules, etc.
- GollumApp - allows attackers to take screenshots, collect information about the network, steal passwords stored in web browsers, read keystrokes and communicate with C&C servers.

Later, current and former U.S. intelligence officials told CyberScoop that Slingshot represented a U.S. military program run out of Joint Special Operations Command (JSOC), a component of Special Operations Command (SOCOM).

APT name	Regions attacked	Operation start
Chafer	Israel, Jordan, United Arab Emirates, Saudi Arabia, Turkey	2017

In February 2018, researchers at Symantec reported new tools being deployed the Chafer hacker group.

Since 2017, Chafer has sent spear phishing emails with malicious documents to the addresses of specific employees of the companies. The documents contained Excel spreadsheets. When opened, they downloaded a malicious VBS file that in turn ran a PowerShell script. Several hours later, a dropper would appear on the compromised computer. Using this technique, attackers stole the contents of the clipboard, took screenshots, recorded keystrokes and collected files and user credentials. After this initial activity, the attackers usually downloaded more of their tools to the computer using a PowerShell downloader and began moving across the victim's network.

According to the study, the majority of the tools used by hackers are publicly available. For example, hackers began to use the EternalBlue exploit for a vulnerability in the SMB protocol, developed by the US National Security Agency.

The Iranian hacker group Chafer has been active since at least July 2014, attacking the Middle East.

APT name	Regions attacked	Operation start
Sanny APT	Global	March 2018

In March 2018 security specialists discovered a spear-phishing campaign of the "Sanny APT" group, targeting government institutions across the world. The attackers sent e-mails containing a malicious attachment masqueraded as a Microsoft Word document covering geopolitical issues. One of the two detected samples of decoy documents (РГНФ 2018-2019.doc) is written in Russian and relates to the Eurasian policy, the second file (Copy of communication from Security Council Committee (1718).doc) is written in English and discusses on humanitarian operations in the Democratic People's Republic of Korea.

Attachments contain a built-in malicious macro that downloads the encoded .bat file from the URL (http://more.1apps[.]com/1.txt) and decodes it. When executed, the .bat file loads one of the versions of the .cab file (depending on the operating system) that contains the user credential management component, the SANNY malware component, and the configuration file.

The malicious program collects system information and sends it to the C&C server using through FTP. After successful connection to the FTP server, the malicious program extracts from it a file with the commands that must be executed on the victim's machine. The commands used are *chip* (to update the FTP server configuration file), pull command (to upload files to the server), put command (to copy an existing file to a new location on the system), default command (for execution with WinExec ()), /user (to execute commands under the authorized user).

The Sanny APT group was first discovered back in 2012 when it attacked Russian organizations in across several sectors, including space research, IT, education, and telecommunications. Experts at FireEye believe that this is a Korean group of hackers.

APT name	Regions attacked	Operation start
Olympic Destroyer	South Korea	February 2018

The key international event of February – the Winter Olympics in PyeongChang, South Korea – could not do without cyber-attacks. During the opening ceremony on February 9, the Olympic Destroyer virus attacked the organizers' computer networks, which resulted in problems with live streaming and difficulties with the Wi-Fi network and pyeongchang2018.com.

The hackers used Olympic Destroyer, a strain of malware that destroys files and disables systems. The malware uses the EternalRomance NSA exploit for distribution via SMB. The same pattern was tracked during a ransomware attack in 2017.

However, researchers could not agree on who was behind the cyber-attacks. Initially experts blamed the North Korean Lazarus group, but they later connected the attack with a Russian-speaking APT group called Fancy Bear.

APT name	Regions attacked	Operation start
Targeted attack on Germany's government	Germany	2016

In February 2018, Germany's government officials confirmed that the government's information technology networks were infiltrated by hackers last year. The German Government discovered the intrusion in December 2017 but the experts believe that the hackers were inside the networks as long as a year.

Hackers reportedly infiltrated the government's "Informationsverbund Berlin-Bonn" (IVBB) network, a specially designed communications platform. IVBB is one of three networks managed by the German Interior Ministry.

Purportedly, the attackers gained access by burying hidden coded instructions into emails which they sent to staffers' Microsoft Outlook inboxes. Also, there us a hypothesis that hackers breached the network of government computers by leveraging a vulnerability in the ILIAS E-Learning training platform.

Unidentified hackers were originally linked to the Russian-speaking threat actor Fancy Bear, also known as APT28 and Sofacy. Later, through comparison of the techniques applied, researchers determined that the attack was likely carried out by a different threat actor the Turla group (aka Snake, Uruburos).

APT name	Regions attacked	Operation start
Targeted attack on UK Anti-Doping (UKAD)	Great Britain	March 2018

On March 24-25, 2018, the UK Anti-Doping Agency foiled an attempted cyberattack that tried to access confidential medical and drug-testing data. But its experts are now confident that no data was lost or compromised.

Although the culprits have yet to been identified, some media resources (Guardian and others) are linking this attack with the APT28 hacker group, who have hacked the World Anti-Doping Agency's athlete management database.

APT name	Regions attacked	Operation start
Targeted attack on a Hong Kong Telecommunications company	Hong Kong	March 2018

An attack leveraging the compromised website of a Hong Kong telecommunications company was discovered in March 2018. Security experts at Morphisec reported that attackers added an embedded Adobe Flash file that exploits the Flash vulnerability CVE-2018-4878 on the main home.php page.

The flaw exists in Adobe Flash Player 28.0.0.137 and earlier versions. This vulnerability occurs due to a dangling pointer in the Primetime SDK. Successful exploitation could potentially allow an attacker to take control of the affected system.

After exploiting the vulnerability, a shell code is executed. The shell code executes a legitimate Windows process, and overwrites its memory with malicious code. The code downloads additional code, which includes Metasploit Meterpreter and Mimikatz modules.

At the reporting time, the attack has not been attributed to a specific hacker group. The investigation is ongoing.

Threats to blockchain projects and cryptocurrencies

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT name	Regions attacked	Related notifications	Operation start
Lazarus	Global	CP-1666	2017

Since 2017, the Lazarus hacking group has been conducting an aggressive Bitcoin-stealing campaign. This new campaign, dubbed HaoBao, uses spear phishing emails with malicious emails, posed as employee recruitment.

The campaign lasted from April to October 2017 and used job descriptions relevant to target organizations, in both English and Korean. The 2017 campaign targets ranged from defense contractors to financial institutions, including crypto currency exchanges. The objective was to gain access to the target's environment and obtain key military program insight or steal money.

On January 15, 2018, researchers discovered a malicious document masquerading as a job recruitment for a Business Development Executive located in Hong Kong for a large multi-national bank. The document was distributed via a Dropbox account.

On March 1, 2018, Group-IB notified the customers that, since late February 2018, the Lazarus cybercrime group had been attacking clients of the Falcon Coin cryptocurrency-lending platform. The spear phishing email contained a malicious file named "AGREEMENT.docx". The document appears to be an agreement template for Bitcoin distribution between a customer and a cryptocurrency exchange. The Bankshot Trojan implant was attached to the document. Bankshot serves as a backdoor: it performs control server communications, handles commands issued by the control server, and uninstalls self from the system.

Hackers exploit a critical vulnerability (CVE-2018-4878), which exists in Adobe Flash Player 28.0.0.137 and earlier versions. This vulnerability occurs due to a dangling pointer in the Primetime SDK. Successful exploitation allows an attacker to take control of the affected system.

Later, experts observed the Lazarus Group using the Bankshot implant in targeted attacks against the financial organizations in Turkey.

APT name	Regions attacked	Operation start
Coincheck cryptocurrency exchange hack	Japan	January 2018

Japan-based Coincheck, one of the largest cryptocurrency exchanges in Japan, was infiltrated on January 26, resulting in the loss of $533 million in XEM, the native cryptocurrency of NEM. Coincheck confirmed the attack and reported that they intend to refund the stolen funds to nearly 260,000 users from their own capital.

While the attackers have yet to be identified, intelligence officials in South Korea reportedly believe that North Korean hackers may be responsible for this massive theft of cryptocurrency. According to The National Intelligence Agency of South Korea, a number of distinctive features inherent in the operations of North Korean hackers was found in the attack on the Japanese exchange. Investigators believe that the current attack on Coincheck has much in common with the attack on the South Korean exchange Youbit, which occurred in December last year.

In addition to NEM cryptocurrency, security researchers believe that hackers also moved $110 million worth of Ripple (XRP) cryptocurrency after the hack.

APT name	Regions attacked	Operation start
BlackWallet cryptocurrency exchange hack		January 2018

BlackWallet, a web-based wallet application for the Stellar Lumen cryptocurrency (XLM) was attacked by hackers in January 2018. Unknown attackers changed the DNS entry for the BlackWallet.co domain and stole $400,000 in the Stellar Lumen cryptocurrency (XLM) from users' accounts.

The DNS hijacking attack, which was redirecting BlackWallet requests to the website of attackers was discovered on the evening of January 13. In the event the victim had over 20 Lumens, attackers pushed them to their own wallet. In total, the attacker collected 669,920 Lumens, which is about $400,192 at the current XLM/USD exchange rate.

According to the BlackWallet representatives, the incident took place after someone accessed the hosting provider account. The attackers immediately started moving funds from the XLM account to Bittrex, a cryptocurrency exchange, in the attempt to launder them and hide traces by converting in other digital currency.

APT name	Regions attacked	Operation start
Targeted attacks using RubyMiner	Great Britain, Germany, the USA, Norway, Sweden	January 2018

Security researchers at Check Point and Certego have found a new strain of malware targeting Linux and Windows servers running outdated software to secretly mine cryptocurrency. Named RubyMiner, this malware attacks massively web servers in the US, UK, Germany, Norway and Sweden. Despite the large number of compromise attempts observed, only 700 servers worldwide have been successfully enslaved within the first 24 hours of attacks.

The team behind the malware RubyMiner uses a web server fingerprinting tool called p0f to scan and identify Linux and Windows servers running outdated software. The infection campaign is targeting vulnerabilities in PHP, Microsoft IIS, and Ruby on Rails, which were discovered back in 2012-2013. After the criminals install on the servers a modified version of the legitimate application XMRig for "mining" of the Montero crypto currency. The malicious script downloads and installs a modified version of the legitimate XMRig Monero. Experts have analyzed the wallet address which was found on the XMRig miner installed by the RubyMiner malware and estimate the earnings to reach approximately $540.

APT name	Regions attacked	Operation start
Theft of crypto currency worth 570 million won	South Korea	March 2018

Unidentified hackers stole a crypto currency worth 570 million won ($470,588) from a user in South Korea.

According to investigation results, the funds were withdrawn from five e-wallets. The victim’s had a paid anti-virus program installed, which is confirmed to have been hacked.

Data leakage

GROUP IB

GLOBAL CYBER SECURITY COMPANY

- In early March, the Expedia-owned travel website Orbitz disclosed that 880,000 payment cards may have been exposed in a data breach. Customers' personal information, including full names, payment card information, birth dates, phone numbers, email addresses, physical addresses, billing addresses and genders, may have been exposed in the breach. The ongoing investigation has not yet confirmed that criminals accessed all the above-mentioned data.
- The Equifax international credit agency has admitted that the hack on its systems in September 2017 was far worse than previously thought and that criminals were able to steal sensitive personal information on 145 million customers in the US, UK and Canada. The international credit agency previously said that hackers were able to access names, addresses, dates of birth and credit score data from user accounts during the breach, as well as financial information and driver licences in some instances. However, it is now emerged that hackers were also able to access US taxpayer ID numbers and their associated email addresses and phone numbers as well as bank card details.
- A critical vulnerability discovered in the Chrome browser extension of the grammar-checking software Grammarly inadvertently left all 22 million users' accounts, including their personal documents and records, vulnerable to remote hackers. According to researchers, the extension exposed authentication tokens to all websites that could be grabbed by the remote attacker. The vulnerability allows any website to access "documents, history, logs, and all other data" associated with Grammarly accounts.
- In late March, US Sports apparel manufacturer Under Armour disclosed that data associated with 150 million users of the company's fitness app MyFitnessPal were compromised in one of the biggest hacks in history in February 2018. The unauthorized party compromised MyFitnessPal servers and accessed user data including usernames, email addresses, and hashed passwords — the majority with the hashing function called *bcrypt* used to secure passwords. The company said that social security numbers, driver license numbers and payment card data were not compromised.